

Cybersecurity Scenario (30 points)

Threat Intelligence Report (10 points):

1. Types of attacks that could be used:

- SQL Injection: Inserting malicious SQL commands to access or manipulate the database.
- Cross-Site Scripting (XSS): Injecting harmful scripts into web pages viewed by users.
- Cross-Site Request Forgery (CSRF): Tricking users into performing unwanted actions on a web app.
- Path Traversal: Accessing files outside intended directories on the server.
- Brute-force attacks: Trying many password combinations to gain access.
- Denial-of-Service (DoS): Overloading the system to disrupt services.
- Malware: Using malicious software to gain access or steal data.

2. How a vulnerability exploited can provide access to the network:

When a vulnerability in a web application is exploited, attackers can run harmful commands, steal credentials, or bypass security controls. For example, SQL injection can give attackers direct access to data, while XSS can hijack user sessions. Once inside, attackers move laterally within the network, gaining access to sensitive areas and systems.

3. Preventive measures to avoid similar incidents:

- Regularly apply security patches and updates to web applications.
- Use input validation and sanitize all user inputs.
- Implement Web Application Firewalls (WAF) to filter malicious traffic.
- Enforce strong password policies and multi-factor authentication.
- Conduct regular security audits and vulnerability assessments.
- Educate employees about phishing and social engineering risks.
- Monitor network traffic for unusual activity and respond promptly.

Incident Response Plan (10 points):

1. Outline an incident response plan to address the breach.

Most businesses need a cybersecurity incident response plan (CSIRP) because they are subject to some regulatory obligation that requires them to have such a plan. Every business needs such a plan because having one is just good business sense.

For example, if your organization suffers a breach and you have no response plan, your security and management teams will scramble to understand and respond. They'll be more likely to make expensive mistakes. They'll need more time to respond to the

breach, which potentially might give the attackers more time to do more damage. All that, in turn, will alienate employees and business partners who will wonder (quite reasonably) whether your management team knows what it's doing.

Below are the check lists for the IRP:

- **Preparation:** Ensure the incident response team, tools, and processes are ready.
- **Identification:** Detect and confirm the security breach through monitoring and alerts.
- **Containment:** Act quickly to limit the damage and stop the attacker from spreading further.
- **Eradication:** Find and remove the root cause of the breach, such as unpatched vulnerabilities or malware.
- **Recovery:** Restore systems to normal operation and verify they are secure before resuming services.
- **Lessons Learned:** Review the incident to improve future security and response processes.

2. Steps for Containment, Eradication, and Recovery

Containment:

- Immediately isolate affected systems from the network to prevent attackers from moving inside.
- Disable compromised user accounts or credentials.
- Apply temporary fixes like firewall rules to block malicious traffic.

Eradication:

- Identify and remove malware, backdoors, or unauthorized access points.
- Patch the vulnerable web application and other affected software.
- Verify that all traces of the attackers' presence are eliminated.

Recovery:

- Restore systems carefully from trusted backups if needed.
- Monitor systems for any signs of the attack returning.
- Gradually reconnect systems to the network and resume normal operations.
- Communicate with stakeholders about the status and resolution of the breach.

Network Security Measures (10 points)

1. Recommended Network Security Technologies and Practices

- Layered security: Protect at multiple layers like identity, endpoint, network, and application also apply least-privilege access and require MFA for all users and admins.

- Firewalls and segmentation: Allow only required ports/IPs with cloud firewalls (e.g., Azure Firewall, AWS Network Firewall). Segment networks (web, app, DB) and keep sensitive systems in restricted subnets.
- Hardening and patching: Patch internet-facing services first; automate updates where possible. Disable unused services and close unnecessary ports.
- Web app protection: Put a WAF in front of public apps to block common attacks (SQLi, XSS). Enable DDoS protection to keep services available during traffic spikes.

There are few other points to consider like Endpoint and server security, monitoring and logging, access control and secrets, data protection, configuration and compliance etc which are recommended.

2. **Include at least three different security technologies or practices (e.g., IDS/IPS, firewalls, network segmentation).**

IDS/IPS (Threat detection)

- Turn on managed threat detection to spot port scans, brute-force logins, suspicious lateral movement, and unusual data transfers in near real time.
- Route all findings to a central security dashboard where alerts are triaged quickly; use automated playbooks to isolate a host, block an IP, or disable a risky account.
- Tune detection rules to reduce false positives (e.g., whitelist known scanners, set thresholds by environment) and review alerts daily.

Firewalls

- Use cloud firewalls and security groups/NSGs to allow only required ports and trusted IP ranges; deny everything else by default.
- Enforce application-layer rules where possible (e.g., only HTTPS to web tier, only database port from app tier).
- Control outbound (egress) traffic: restrict destinations, block risky regions, and allow only needed protocols to lower data exfiltration risk.
- Log all allow/deny decisions and alert on policy violations or sudden rule changes.

Network segmentation

- Separate web, application, and database tiers into distinct subnets/VNETs/VPCs with dedicated route tables and ACLs to contain any compromise.
- Apply strict east-west controls: only permit necessary flows between tiers (e.g., web→app on 443, app→DB on 1433/3306), and block lateral movement within the same tier where possible.
- Use micro-segmentation for sensitive systems (payments, PII) so only specific service accounts or workloads can communicate.

- Regularly review and test segmentation (e.g., connectivity tests, micro-pen tests) to ensure rules match the intended design.

SIEM (centralized logging, detection, and response)

- Centralize logs from identity, endpoints, applications, networks, and cloud services into a single SIEM for real-time correlation and alerting.
- Create high-signal detection rules (e.g., many failed admin logins, new public-facing endpoints, unusual data egress) and map them to response playbooks.
- Use threat intelligence feeds to enrich alerts with IP/domain reputation and known TTPs; prioritize incidents based on risk and business impact.
- Retain logs for an appropriate period (e.g., 90–180 days+), enable immutable storage for critical sources, and run regular searches/hunts for stealthy activity.